

BAŞLIK: Kimlik Doğrulama ve Güvenlik — Tekrar Soruları

TÜR: Bölüm Sonu Tekrar Testi (12 Soru)

SORULARIN CEVAPLARI EN ALTTA BULUNMAKTADIR.

1. Authentication (Kimlik Doğrulama) ile Authorization (Yetkilendirme) arasındaki fark nedir?

- A) Authorization önce, Authentication sonra yapılır
- B) Authentication 'sen kimsin' sorusuna, Authorization 'bu işleme yetkin var mı' sorusuna cevap verir
- C) Authentication sadece mobil uygulamalarda kullanılır
- D) İkisi de aynı şeydir

2. API Anahtarlarının (API Keys) en zayıf yönü nedir?

- A) Hiç kullanılamazlar
- B) JSON formatını desteklemezler
- C) Çalınırsa genellikle süresiz geçerli kalır ve genelde kullanıcı bazlı değil uygulama bazlıdır
- D) Sadece HTTPS ile çalışırlar

3. Basic Authentication neden MUTLAKA HTTPS üzerinden kullanılmalıdır?

- A) Çünkü Basic Auth sadece HTTPS'te tanımlıdır
- B) Çünkü tarayıcılar HTTP'yi desteklemez
- C) Çünkü HTTP daha yavaştır
- D) Çünkü Base64 kodlama şifreleme değildir, düz metin gibi kolayca çözülebilir

4. Bir JWT (JSON Web Token) hangi 3 parçadan oluşur?

- A) Key, Value, Hash
- B) Auth, Token, Secret
- C) Header, Payload, Signature
- D) Header, Body, Footer

5. JWT'nin Payload (yük) kısmı için doğru ifade hangisidir?

- A) Sadece Base64Url ile kodludur, şifreli değildir; herkes okuyabilir
- B) Sadece sunucu tarafından oluşturulabilir, hiç değiştirilemez
- C) Şifrelidir, kimse okuyamaz
- D) Her zaman boştur

6. JWT kullanmanın en büyük avantajı nedir?

- A) Süresiz geçerli olması
- B) Sadece mobil uygulamalarda çalışması
- C) Sunucunun durum tutmasına gerek kalmaması (stateless doğrulama)

D) Şifreleme gerektirmemesi

7. OAuth 2.0 tipik olarak hangi senaryoda kullanılır?

- A) Sadece dosya sıkıştırma işlemlerinde
- B) Sadece yerel ağ içi iletişimde
- C) Veritabanı indexleme için
- D) Bir kullanıcının şifresini üçüncü bir uygulamayla PAYLAŞMADAN, o uygulamaya sınırlı erişim izni vermesi

8. OAuth 2.0 Authorization Code akışında, istemci uygulama access token'ı NE ZAMAN alır?

- A) Hiçbir zaman, sadece yetkilendirme sunucusu token'a sahip olur
- B) Yetkilendirme kodu (authorization code) alındıktan sonra, bunu client secret ile değiştirerek
- C) Sadece kullanıcı şifresini doğrudan alarak
- D) Kullanıcı giriş yapar yapmaz, hiçbir aracı olmadan

9. Token Bucket (Jeton Kovası) hız sınırlama algoritması nasıl çalışır?

- A) Sadece günlük toplam istek sayısını sınırlar
- B) Sadece IP adresine göre sınırlama yapar
- C) Her istek sırayla bir kuyrukta bekletilir
- D) Kova sabit hızda jetonla doldurulur, her istek 1 jeton harcar; kova boşsa istek reddedilir

10. Bir 429 yanıtında, istemciye NE ZAMAN tekrar deneyebileceğini bildiren başlık hangisidir?

- A) Retry-After
- B) Content-Type
- C) Authorization
- D) ETag

11. BOLA (Broken Object Level Authorization) zafiyeti en temelde neyi ifade eder?

- A) Sunucunun asla çökmemesi
- B) Bir kaynağa erişimde, kaynağın GERÇEKTEN o kullanıcıya ait olup olmadığının kontrol edilmemesi
- C) Şifrelerin hiç hashlenmemesi
- D) API'nin hiç dokümanate edilmemesi

12. CORS (Cross-Origin Resource Sharing) mekanizması ne işe yarar?

- A) Tarayıcının, hangi domain'lerin API'ye JavaScript ile istek atabileceğini kontrol etmesini sağlar
- B) Şifreleri hashler
- C) API yanıt sürelerini hızlandırır
- D) Veritabanı yedeklemesi yapar

CEVAP ANAHTARI

1-B 2-C 3-D 4-C 5-A 6-C 7-D 8-B 9-D 10-A 11-B 12-A